CYBER THREAT MODELING & RESEARCH WHITE PAPER

The 4X Cyber Attack Framework: Modeling Autonomous Adversary Loops

Aubrey Finn
Offensive Tradecraft & Detection Engineering Research

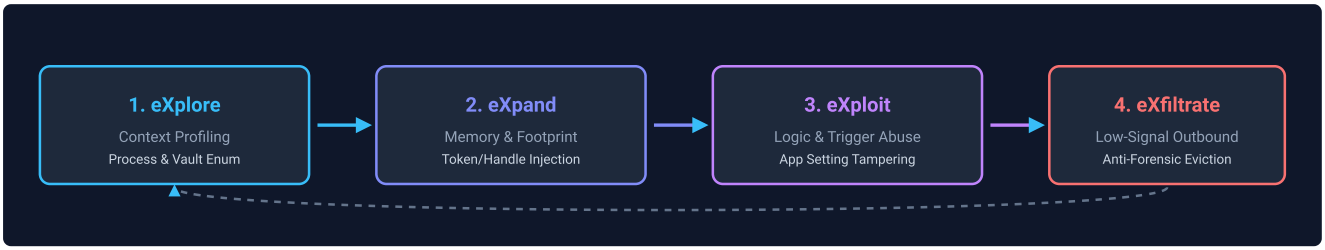
Portfolio Technical Brief

Executive Summary: Linear breach models fail to represent modern agentic tradecraft and automated local payloads. The 4X Framework (*eXplore, eXpand, eXploit, eXfiltrate*) synthesizes strategic state-machine dynamics to model rapid, cyclic attacker loops within compromised endpoints, isolating architectural trust boundaries before encryption barriers are encountered.

1. The Strategic Shift: Linear Chains vs. Autonomous Loops

Traditional defensive postures rely heavily on the Lockheed Martin Cyber Kill Chain and static MITRE ATT&CK matrices. While valuable for taxonomy, these models assume sequential, human-paced progressions across network perimeters. Modern automated threats, offensive LLM agents, and localized loaders operate as continuous state machines. Rather than halting after exploitation, an agent evaluates environmental entropy, executes memory-resident discovery, abuses application trust boundaries, and loops back to adjacent nodes within seconds.

2. High-Level Operational Architecture



3. Phase Taxonomy, Tooling & Technique Association

4X Phase	Attacker Objective	Representative Tools	MITRE ATT&CK Mapping
1. eXplore	Silent context profiling, ambient token discovery, process handle identification	PowerView SharpUp Seatbelt Snaffler	T1057 (Process Discovery) T1082 (System Info) T1552 (Unsecured Credentials)
2. eXpand	User-space footprint growth, inter-process hooking, staging in writable spaces	Donut Cobalt Strike Mimikatz Frida	T1055 (Process Injection) T1053 (Scheduled Task) T1134 (Access Token)
3. eXploit	Application logic abuse, IPC hijacking, configuration manipulation (Triggers)	Custom DLLs KeePass Triggers ProcDot	T1546 (Event Triggered) T1555 (Credentials from Store) T1574 (Hijack Execution)
4. eXfiltrate	Low-signal staging, legitimate telemetry egress, volatile memory eviction	DNSCat2 Cloudflared Living-off-the-Land	T1041 (Exfiltration Over C2) T1070 (Indicator Removal) T1567 (Exfil Over Web)

4. Phase 1 & 2: Contextual Reconnaissance & Memory Pivoting

In **Phase 1 (eXplore)**, modern tooling discards noisy network sweeps in favor of ambient API harvesting. Using localized heuristics, payloads query active window titles, process memory tables, and user app data (e.g., searching for `%APPDATA%\KeePass`, Chrome profile states, and AWS token caches). Instead of evaluating math, the agent models human workflow states.

In **Phase 2 (eXpand)**, the agent establishes footholds without triggering privilege alarms. By operating entirely within the user's active session security context, malware bypasses UAC boundaries, utilizing API calls such as `OpenProcess` with `PROCESS_VM_READ` permissions or writing persistence stubs to unmonitored user-writable runtime directories.

> **Case Study (Endpoint Password Stores):** Threat actors rarely target AES-256 or Argon2id mathematically. Instead, 4X models how malware exploits the local boundary: an agent monitors `KeePass.exe` memory buffers (CVE-2023-32784) or registers an API hook to capture cleartext strings the exact microsecond the user unlocks the database.

5. Phase 3 & 4: Application Logic Abuse & Egress Cycles

Phase 3 (eXploit) bypasses memory corruption exploits entirely by abusing application features. As demonstrated in trigger abuse vectors (CVE-2023-24055), an unprivileged process modifies an application's XML settings to export decrypted data on legit unlock events. In **Phase 4 (eXfiltrate / eXterminate)**, low-signal HTTPS traffic masks extraction before memory is wiped to evade post-incident triage.

6. Defensive Engineering & Telemetry Chokepoints

4X Stage	Telemetry Chokepoint	Detection Strategy	Architectural Mitigation
eXplore	Process enumeration & API hooks	Sysmon Event ID 10 (ProcessAccess to target LSASS/vaults)	Protected Process Light (PPL) & Credential Guard
eXpand	App data file modifications	File integrity monitoring on %APPDATA% configuration paths	Restricted AppLocker/WDAC policies for script engines
eXploit	Child process spawning & IPC pipes	Parent-child anomalies (e.g., vault app spawning `cmd.exe`)	Config enforcement via read-only Admin-enforced XML
eXfiltrate	Outbound egress volume & DNS query spikes	Zeek/Suricata tracking TLS handshakes to unknown hosts	Strict egress firewall filtering and DNS RPZ filtering

7. Research Dossier & Industry Application

Aubrey Finn • *Threat Modeling & Detection Engineering*
This framework reflects research into autonomous threat modeling, memory boundary protection, and endpoint detection engineering. By identifying systemic chokepoints across the 4X lifecycle, security organizations can build resilient detection rules (Sigma/YARA) that disrupt adversary decision engines long before data exfiltration occurs.

Available for: Senior Threat Research, Detection Engineering, Red Team Architecture, and Security Consultation roles. Connect via LinkedIn: `Aubrey Finn`.